

한국서부발전(주) 상임감사위원회

개 선·시 정 요 구

제 목	자료교환시스템 기능 미비점 및 내부통제 강화 필요
소 관 부 서	■■■■■처 □□□□□실
조 치 부 서	■■■■■처 □□□□□실
구 분	정보보안
내 용	

1. 업무 개요

우리 회사에서 운영하는 ‘자료교환시스템’은 임직원이 회사 PC에 보유하고 있는 파일 자료(이하 “파일”이라고 한다)를 외부로 반출하거나 외부의 파일을 회사 PC로 반입하기 위해서 사용하는 양방향 파일 전송시스템으로써 주요 기능으로는 반출 승인을 위한 승인권자 지정, 발신 목적 작성, 첨부파일 보호 기능, 제목 입력 기능, 1회당 첨부파일 용량 제한 기능을 제공하고 있다.

2. 관계규정 및 판단기준

「정보보안업무 처리기준」 제66조(비공개 업무자료 유출방지) 내지 제136조(정보통신보안 규정 위반 및 자료유출 사고) 제2항에 따라 비공개 업무자료 처리 절차 준수여부를 관리·통제할 수 있는 보안체계를 구축·운영하여야 하고, 검증필 암호모듈 등을 사용하여 비공개 업무자료⁵⁾의 위조·변조·훼손 및 유출

5) 정보보안업무 처리기준 제2조(정의) 25. "비공개 업무자료"라 함은 비밀 및 대외비를 제외한 업무자료 중에서 다음 각 목의 어느 하나에 해당하는 자료 또는 정보를 말한다.

가. 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보
다. 가목에 따른 비공개 대상 정보의 주요 내용이 기술된 문장 또는 문구

등을 방지하기 위한 보안대책을 마련하여야 하며, 비밀·대외비 등 국가 기밀에 속하는 업무자료가 유출되거나 비공개 업무자료가 유출된 사고 중 「국가정보원법」 제4조 제1항 제1호 나목부터 마목까지와 관련된 사안일 경우 즉시 국가정보원장에게 통보하여 합동 조사를 시행하도록 명시되어 있다.

3. 감사결과 확인

그런데 감사 결과 자료교환시스템에서는 이용자 기준으로 승인권자 지정, 발신 목적 작성, 첨부파일 보호 기능, 제목 입력 기능, 회당 첨부파일 용량 제한 기능과 같은 필수 기능만이 마련된 것을 확인하였다.

회사의 중요한 정보를 담고 있는 파일을 외부로 반출할 때는 자료가 불필요하게 유출되지 않도록 다양한 방안을 마련하는 것이 필요하며 이를 위해서 ‘자료교환시스템’의 미비점과 기대 효과를 분석하였다.

① 자료의 분류 체계 설정으로 모니터링 및 분석력 강화

일반적으로 회사에서 사용하는 자료의 종류에 대해 분류해 보면 특성에 따라 공문, 계약서, 도면, 기획서, 사규, 홍보물, 동영상, 사진 등 다양한 종류로 물리적인 구분할 수 있는데 반출 시 구분값을 선택하여 분류한다면 시기별, 자료별로 효율적인 모니터링을 할 수 있는 대안이 될 것이다. 또한, 내부 규정에 따라 비공개 업무자료 여부에 대해 선택하도록 하여 관리적 측면에서 편의성을 높이고 향후 감독기관의 자료 제출 등 예방 측면의 대응책 마련이 필요하다.

② 출처 명시로 법적 책임 강화

이용자가 자료를 외부로 반출할 때 영업 비밀을 침해하거나 비밀유지 의무를 위반할 위험은 상존하므로 자료의 생산부서 또는 작성자를 지정토록 기능을 추가하여 자료 반출에 대한 이용자의 법적⁶⁾ 책임을 강화할 필요가 있다. 또한,

자료의 생산부서나 작성자를 알 수 없는 자료도 존재하는바 이용자가 이를 선택할 수 있도록 다양한 상황을 고려한 시스템적 기능 마련이 필요하다.

③ 자료교환 용량 증설 절차 개선으로 ITGC⁷⁾ 내부통제 강화

최초로 부여되는 기본 용량은 300메가바이트(MB)로 용량 증설 필요할 때는 이용자가 담당자에게 유선으로 연락하여 협조받거나 VPN 신청서와 같이 별도의 전용 신청서가 없이 증설하고 있음에 따라 ‘IT서비스 신청’ 웹페이지상 전용 신청서를 통해 정식으로 절차를 거쳐 증설에 대한 사유를 입력하고 일정 기간을 설정하여 담당자의 합의와 상급자의 승인을 통해 증설하는 절차를 도입하는 것이 내부통제 측면에서 필요한 절차라고 판단된다.

관련자 주장 및 판단

■■■■■실 업무 담당자는 감사 지적사항에 대해 동의하며 정보보안 등의 관련 부서와 협의하여 개선하겠다고 하였다.

조치할 사항

■■■■■처장은 ① 관련 부서와의 협조를 통해 자료의 분류 체계를 선정하여 시스템에 반영하시고 출처를 입력할 수 있도록 시스템을 개선하시며 (개선), ② ITGC 내부통제 절차를 준수하도록 별도의 용량 증설 절차를 마련하시기를 바랍니다. (시정)

6) 부정경쟁방지법, 대외무역법, 상표법, 상법, 종자산업법, 반도체집법, 디자인보호법, 실용신안법, 특허법, 저작권법 등

7) 정보기술 일반 통제(ITGC)는 COSO 프레임워크의 통제활동에 속하는 요소로 시스템과 데이터의 신뢰성과 무결성을 보장하는 기본 통제 체계이며 준수하지 않는 경우 보안 위험 증가, 운영 중단, 규제 불이행의 결과를 초래할 수 있음(출처: ChatGPT)